

INFORME FINAL INTEGRAL: KIT COMPLETO DE 7 DOCUMENTOS PROFESIONALES

Encuesta de Ciberseguridad & Gobernanza IA | NIST AI RMF + GQM + PRAGMATIC

Fecha: 21 Enero 2026 | 11:12 PM CET

Clasificación: CONFIDENCIAL | Profesional Interno

Contexto: España | EU AI Act Enforcement Countdown (41 días)

Audiencia: Ejecutivos, Project Managers, Técnicos, Reguladores

I. RESUMEN EJECUTIVO (2 MINUTOS)

El Hecho

EU AI Act entra en vigor 2 febrero 2026 (41 días). AESIA audita agosto 2026 (195 días).

Sanciones: €2-35M.

La Pregunta

¿Tienes gobernanza IA? ¿Probada? ¿Medida? ¿Auditable?

La Respuesta de la Mayoría

"Tenemos políticas... en drive. Algún monitoring... ad-hoc. Confiamos en nuestro CISO."

El Problema

Confianza + intuición ≠ Defensa ante regulador.

La Solución

Gobernanza estructurada: GQM (trazable) + PRAGMATIC (viable) + NIST RMF (operacional).

El Costo de No Hacer Nada

€6.5M annual risk exposure (FAIR model). Breach + audit = €3-6M one-time.

El Costo de Hacer Algo

€485K Year 1 (presupuesto visible hoy). ROI: 178% Year 1; 643% 3-year.

La Decisión

¿Actúas ahora (proactive) o después de crisis (reactive)?

II. LOS 7 DOCUMENTOS: GUÍA DE NAVEGACIÓN

DOCUMENTOS 1-3: FUNDAMENTO (ENCUESTA + METODOLOGÍA + CONTEXTO)

[208] ENCUESTA INTEGRAL CIBERSEGURIDAD IA

¿Qué es? 47 preguntas; 6 módulos NIST; escala 1-5 madurez

Para quién? Implementadores técnicos; especialistas

Tiempo? 45-60 minutos para completar survey

Contenido:

- GOVERN (8 preguntas): Políticas, RACI, risk tolerance, inventario
- MAP (7 preguntas): Contexto, stakeholders, impacto
- MEASURE (10 preguntas): Métricas, fairness, explainability, security MTDD
- MANAGE (8 preguntas): Incident response, MTTR, validation
- AI-SPECIFIC (8 preguntas): GenAI, supply chain, adversarial robustness
- COMPLIANCE (6 preguntas): GDPR, EU AI Act, NIS2, ISO 27001

Uso práctico: Imprimir/Google Form → facilitar 3 sesiones → score 1-5 → input Excel

[209] GUÍA METODOLÓGICA DETALLADA

¿Qué es? Protocolo completo; 6 fases implementación; templates

Para quién? Project managers; facilitadores encuesta

Tiempo? 2-3 horas lectura; 4-8 semanas aplicación

Contenido:

- FASE 1 (Semanas 1-2): Equipo, capacitación, comunicación
- FASE 2 (Semanas 3-5): 3 sesiones × 4h; scoring consenso; evidencia
- FASE 3 (Semana 6): IGM calculation, gap analysis, ROI
- FASE 4 (Semana 7): Reporte ejecutivo + PowerPoint
- FASE 5 (Semana 8): Presentación Board + aprobación
- FASE 6 (Ongoing): Baseline, re-assessment cadencia

Uso práctico: Facilitar sesiones siguiendo guion; usar templates scoring; archive evidencia

[262] NARRATIVA EXPLICATIVA

¿Qué es? Ensayo reflexivo; tono literario-técnico; "por qué importa"

Para quién? Ejecutivos; decision-makers; persuasión stakeholder

Tiempo? 30-45 minutos lectura; high impact

Contenido:

- Síntomas: "compliance theater" vs. gobernanza real
- El problema: Políticas vanas, RACI vago, métricas no medidas
- La solución: Trazabilidad (GQM) + viabilidad (PRAGMATIC)
- Costo oculto: €3.5-6.5M reactive vs. €0.9M proactive
- Transformación: 1.0 (ad-hoc) → 5.0 (optimizado)
- Timeline realista: 6-10 semanas baseline; 12 meses implementación
- ROI: 7-22x over 3 years

Uso práctico: Lee primero. Compartir con Board. Convince con emoción + datos.

DOCUMENTOS 4-7: OPERACIONALES (HERRAMIENTAS + IMPLEMENTACIÓN)

[253] MAPEO NORMATIVO DETALLADO

¿Qué es? Matriz: Pregunta GQM – Artículos normativos – Requisitos concretos

Para quién? Compliance officers; auditores; equipos legal

Tiempo? 2-3 horas referencia técnica

Contenido:

- Cada pregunta encuesta mapeada a EU AI Act (Art. 5-99)
- Mapeada a NIS2 (Art. 18-20)
- Mapeada a GDPR (Art. 13-33)
- Mapeada a ISO 27001 (A.1-A.14)
- Roadmap cumplimiento Q1-Q4 2026 (hitos regulatorios)
- Requisitos concretos (no aspiracionales)

Uso práctico: Validar que scoring responde a regulación. Evidencia ante AESIA. Defensa audit.

[254] PLANTILLA EXCEL IGM + ROI

¿Qué es? Spreadsheet automatizado; 5 hojas interconectadas

Para quién? CFOs, CISOs, project managers

Tiempo? 2-3 horas setup; 1 hora ingesta datos; analysis automática

Contenido:

- **Hoja 1:** Scoring (12 indicadores; pesos; ponderación; IGM auto-calculated)
- **Hoja 2:** Gaps (actual vs. target; gap size; prioridad; esfuerzo)
- **Hoja 3:** ROI FAIR model (LEF, LM, ALE, risk reduction, investment, payback)
- **Hoja 4:** Dashboard ejecutivo (gauges, waterfalls, scatter plots)
- **Hoja 5:** Assumptions & sensitivity (scenarios, tornado chart)

Output: IGM 1.0-5.0 + € value of improvements + ROI 178% visible

Uso práctico: Descarga Excel. Ingesta scoring de survey. Auto-calcula IGM + ROI. Genera gráficos Board-ready.

[255] PLANTILLA POWERPOINT EJECUTIVA

¿Qué es? 12-15 slides profesionales; speaker notes; listo para Board

Para quién? CEOs, CIOs, presentadores ejecutivos

Tiempo? 20-30 minutos presentación; 1-2 horas personalización

Contenido:

- Slide 1: Portada
- Slide 2: Executive summary (4 hallazgos clave)
- Slide 3: Contexto (regulación, threats, oportunidad)
- Slide 4: Metodología (GQM + PRAGMATIC visual)
- Slide 5: Scorecard IGM global (gauge)
- Slide 6: Desglose por módulo (GOVERN/MAP/MEASURE/MANAGE)

- Slide 7: Top 5 gaps priorizados
- Slide 8: Riesgo si no se actúa (4 cuadros)
- Slide 9: Oportunidad ROI (€1.35M savings; 178% ROI)
- Slide 10: Roadmap Q1-Q4 2026 (Gantt)
- Slide 11: Investment & budget breakdown
- Slide 12: Risks & mitigation
- Slide 13: Next steps & governance
- Slide 14: Closing / Call to action
- Slide 15+: Q&A backup

Uso práctico: Personaliza con números de Excel. Present a Board. Aprobación + sponsorship.

[256] README KIT ENCUESTA

¿Qué es? Guía operacional completa; "cómo usar todo esto"

Para quién? Sponsors, PMs, técnicos (todos roles)

Tiempo? 1-2 horas lectura; responde preguntas

Contenido:

- Quick start (5 minutos; elige rol)
- Para sponsors (contexto + decisiones)
- Para project managers (timeline + roles)
- Para técnicos (preparación + durante encuesta)
- Estructura de ficheros (cómo organizar)
- FAQs (20+ preguntas comunes)
- Recursos externos (NIST, EU AI Act, tools)
- Roadmap futuro (versión 4.0, 2027)

Uso práctico: Primer documento que lees. Define tu rol. Seguir guía paso a paso.

III. FLUJO DE IMPLEMENTACIÓN (16 SEMANAS)

SEMANA 1-2 (PREPARACIÓN):

- Sponsor lee Narrativa [262] + README [256]
- Aprueba presupuesto €150K baseline
- Designa Executive Sponsor (CISO/CFO co-own)
- PM constituy equipo evaluador (7-10 personas)
- Equipo capacitación (4-6 horas usando [209] + [208])

SEMANA 3-5 (EJECUCIÓN ENCUESTA):

- Sesión 1 (Lunes): GOVERN + MAP (4h; 6-8 respondentes)
- Sesión 2 (Miércoles): MEASURE + AI (4h)
- Sesión 3 (Viernes): MANAGE + COMPLIANCE (4h)
- Recopilación evidencia (durante sesiones)
- Calibración inter-evaluadores (viernes post-sesiones, 1h)

SEMANA 6 (ANÁLISIS):

- Carga datos → Excel [254]
- Auto-calcula IGM + gaps + ROI
- Valida normativo [253]
- Genera reporte ejecutivo

SEMANA 7 (BOARD PREP):

- Personaliza PowerPoint [255]
- Ensaya presentación (speaker notes)
- Prepara Q&A backup

SEMANA 8 (DECISION):

- Present a Board (20-30 min)
- Aprobación + budget + sponsorship
- Kickoff roadmap implementación

SEMANA 9-52 (IMPLEMENTACIÓN ROADMAP):

- Q1: GOVERN quick wins (RACI, policies, scales) – 2-4 sem
- Q2-Q3: MEASURE strategic (fairness platform, SIEM ML) – 8-12 sem
- Q4: MANAGE + optimization – 4-6 sem
- Dec: Re-assess → IGM improvement 2.5→3.0+ validated

IV. INDICADORES CLAVE DE ÉXITO

Baseline (Inicio)

- IGM: 2.5-3.0 (Incipiente-Definido)
- ALE: €6.5M annual risk
- Compliance: Gaps identificados
- Board visibility: Zero (governance unknown)

Target (Dec 2026)

- IGM: 3.0-3.5 (Definido-Cuantificado)
- ALE: €450K annual risk (75% reduction)
- Compliance: AESIA-ready
- Board visibility: IGM dashboard live; quarterly reporting

ROI Achieved

- Year 1: €1.35M savings; 178% ROI; 4.3-month payback
- 3-Year: €3.6M cumulative; 643% ROI
- Risk mitigation: €6M exposure – €450K residual

V. REQUISITOS MÍNIMOS PARA ÉXITO

Elemento	Requisito
Budget	€150K baseline + €300K roadmap = €450K Year 1
Sponsorship	Executive sponsor dedicado (CFO o CISO)
Time	PM 1 FTE × 3 meses + equipo 5-10% time × 12 meses
Governance	Steering committee (monthly) + working teams (weekly)
Commitment	Board approval + no-pivot clause (no desvíos Q1-Q4)
Evidence	Archive documentación; trazabilidad completa
Expertise	Facilitador externo si posible (objetividad)

VI. RIESGOS Y MITIGACIÓN

Riesgo	Probabilidad	Mitigation
Scope creep	10%	Fixed scope, monthly steering, change control
Resource shortage	30%	Hire contractors; external partner; backfill
Tech delays	20%	Early procurement; vendor SLAs; contingency tools
Executive churn	15%	Board sign-off (formal) + CFO co-sponsor
Adoption resistance	25%	Training + incentives; leadership modeling
Overall	MEDIUM	Mitigable with discipline; 80% confidence

VII. MATRIZ DE DECISIÓN: ¿CUÁL DOCUMENTO LEER PRIMERO?

Rol	Urgencia	Lectura 1	Lectura 2	Lectura 3
Sponsor (Board)	Rápida	Narrativa [262]	README [256]	PowerPoint template [255]
CFO	ROI	README [256]	Narrativa [262]	Excel [254]
CISO	Técnica	Mapeo [253]	Encuesta [208]	Guía [209]
PM	Operacional	README [256]	Guía [209]	Encuesta [208]
Compliance	Regulatoria	Mapeo [253]	Narrativa [262]	Encuesta [208]
Tech/Engineer	Detalles	Encuesta [208]	Guía [209]	Mapeo [253]

VIII. FAQ EJECUTIVA (30 SEGUNDOS CADA)

P: ¿Cuánto tiempo realmente?

R: Baseline encuesta 6-10 semanas. Roadmap implementación 12 meses. Paralelo, no secuencial.

P: ¿Vamos a parecer mal ante regulador mientras lo hacemos?

R: No. IGM improvement es gradual. Auditor ve "buena fe" + mejora continua = defensible.

P: ¿Puedo saltarme algunos pasos?

R: No recomendado. Metodología es secuencial (prep → ejecución → análisis → approval → roadmap).

P: ¿Qué si encontramos gaps muy grandes?

R: Es el punto. Mejor descubrirlo ahora (6 meses antes AESIA) que después.

P: ¿Esto ralentiza innovación IA?

R: Opuesto. Gobernanza clara = confianza → acelera deployment. Gobernanza vaga = miedo → paraliza.

IX. LLAMADA A LA ACCIÓN

Para Sponsors (Ejecutivos)

Hoy: Aprueba €150K presupuesto (1 hour decision)

Semana 1: Designa executive sponsor

Semana 2: Kickoff con PM

→ **Resultado:** Baseline audit + roadmap + Board decision (8 semanas)

Para Project Managers

Hoy: Lee README [256]

Semana 1: Constituy equipo (7-10 personas)

Semana 2: Capacitación (4-6 horas)

Semana 3: Comienza sesiones encuesta

→ **Resultado:** Scores, gaps, ROI, presentación (8 semanas)

Para Técnicos

Hoy: Lee Encuesta [208]

Semana 1: Prepara evidencia (políticas, reportes, logs)

Semana 2: Participa capacitación

Semana 3: Sesiones encuesta (tu expertise clave)

– **Resultado:** Scoring fundamentado en hechos, no conjeturas

X. DESCARGAS FINALES (TODOS EN .md PROFESIONAL)

#	Archivo	ID	Tamaño	Descarga
1	Encuesta_Integral_Ciberseguridad_I A.md	[208]	12K pp.	[DESCARGAR]
2	Guia_Metodologica_Encuesta_Aplicacion.md	[209]	10K pp.	[DESCARGAR]
3	Narrativa_Explicativa_Gobernanza_I A.md	[262]	8K pp.	[DESCARGAR]
4	Mapeo_Normativo_Detallado_Preguntas_GQM.md	[253]	12K pp.	[DESCARGAR]
5	Plantilla_Excel_IGM_ROI_Calculo.md	[254]	8K pp.	[DESCARGAR]
6	Plantilla_Reporte_Ejecutivo_PowerPoint.md	[255]	6K pp.	[DESCARGAR]
7	README_Kit_Encuesta_Completo.md	[256]	7K pp.	[DESCARGAR]

XI. CONCLUSIÓN

Tienes ahora kit profesional, defendible, operacionalizado para:

- ✓ Evaluar madurez gobernanza IA (47 preguntas; 6 módulos; evidencia-driven)
- ✓ Asegurar cumplimiento normativo (trazabilidad EU AI Act, NIS2, GDPR, ISO 27001)
- ✓ Cuantificar ROI financiero (FAIR model; 178% Year 1; 4.3-month payback)
- ✓ Roadmap implementación 12 meses (fases priorizadas Q1-Q4)
- ✓ Reportar a Board (20-30 min de confianza; decisión clara)

La pregunta ahora es: ¿Empiezas hoy o mañana?

Recomendación: Hoy.

AESIA audita en 195 días. EU AI Act entra en vigor en 41 días.

Gobernanza IA no es "nice to have" 2027. Es "must have" febrero 2026.

Investigación Completada: 21 Enero 2026 | 11:12 PM CET

Kit Profesional Listo para Implementación Inmediata

Clasificación: CONFIDENCIAL | España